

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)
Department of Computer Science and Engineering
ASSESSMENT TOOL 2 – INCIDENT ANALYSIS (ROOT CAUSE & RISK)

Course Code:	CSA5802	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 2
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Incident Investigation, Root Cause Analysis and Risk Assessment.		
Student Name:	Krithika M	Reg. No.:	192521385
Section / Batch:	IT-2025	Date:	

Instructions to Students

- Review the given security incident scenario, evidence, logs and indicators carefully before beginning the analysis.
- Identify the incident sequence, affected assets, relevant indicators and supporting evidence without making unsupported assumptions.
- Determine the root cause by linking observed events, vulnerabilities and contributing conditions in a logical sequence.
- Assess identified risks based on likelihood, severity and potential technical or operational impact.
- Present investigation findings, root-cause reasoning and risk assessment clearly with appropriate technical justification.

Question Type	Focus Area	Questions	Marks
INCIDENT ANALYSIS	Investigation & Risk	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

1. Introduction

Security Incident Analysis: Repeated Unauthorized EHR Access Attempts Through a Doctor Account The given ICS alerts indicate that **unauthorized commands are being transmitted from the IT network toward the PLC/SCADA segment**. This is a serious security incident because an attacker who gains access to the IT network may attempt to move into the OT (Operational Technology) environment and manipulate industrial processes. The main objectives are to:

- Investigate the unauthorized communication.
- Identify the root cause.
- Assess the risks to the organization.

- Contain and recover from the incident.
- Strengthen IT/OT security using an industrial DMZ, allowlisting, jump servers, and OT IDS.

2. Incident Investigation

Step 1: Identify the Incident

The first step is to analyze the ICS security alerts and identify:

- Source IP address and hostname.
- Destination PLC/SCADA device.
- Date and time of communication.
- Industrial protocol used.
- Type of unauthorized command.
- User account associated with the activity.
- Number of commands sent.
- Whether the PLC accepted or executed the commands.

For example:

IT Workstation → Firewall → PLC/SCADA

If the IT workstation is not authorized to communicate directly with the PLC, the activity should be treated as suspicious.

Step 2: Collect Evidence

The following evidence should be collected:

- Firewall logs.
- Router and switch logs.
- IDS alerts.
- SCADA server logs.
- PLC event logs.
- Authentication logs.
- Windows/Linux system logs.
- Endpoint security alerts.
- VPN logs.
- Network traffic records.

Evidence should be preserved so that it can be used for forensic investigation.

Step 3: Analyze the Source System

The suspicious IT system should be checked for:

- Malware.
- Suspicious processes.

- Unauthorized applications.
- Recently installed software.
- Compromised accounts.
- Suspicious remote connections.
- Phishing-related activity.
- Unusual outbound network traffic.

Step 4: Analyze the PLC/SCADA System

The security team should determine:

- Which PLCs received commands.
- Whether commands were accepted.
- Whether process parameters were changed.
- Whether alarms were generated.
- Whether any equipment behaved abnormally.
- Whether the PLC configuration was modified.

Step 5: Determine the Attack Path

A possible attack path is:

Attacker → IT System → Compromised Account → IT Network → OT Network → SCADA → PLC

Finding this path helps identify the security control that failed.

3. Root Cause Analysis

The most likely root cause is **insufficient separation between the IT and OT networks**.

Primary Root Cause

The IT network has excessive connectivity to the PLC/SCADA environment. A compromised IT system can therefore communicate with critical OT devices.

Contributing Causes

1. Poor Network Segmentation

IT and OT networks may be directly connected without adequate security boundaries.

2. Weak Firewall Rules

Firewall rules may allow unnecessary protocols or unrestricted communication between IT and OT.

3. Lack of Industrial DMZ

There may be no controlled intermediate network between corporate IT and industrial OT.

4. Excessive Privileges

Users or systems may have more permissions than required.

5. Weak Authentication

Compromised passwords or shared accounts may allow unauthorized access.

6. No Allowlisting

Unauthorized applications may execute commands or communicate with industrial devices.

7. Direct Administrative Access

Administrators may connect directly from IT workstations to PLC/SCADA systems.

8. Insufficient Monitoring

The organization may not have an OT-specific IDS capable of understanding industrial protocols.

Root Cause Chain

Weak IT security → IT system compromise → Unauthorized network access → OT connectivity → Unauthorized PLC commands

4. Risk Assessment

Risk assessment determines the probability and impact of the incident.

Threat	Likelihood	Impact	Risk Level
Unauthorized PLC commands	High	Very High	Critical
SCADA compromise	High	Very High	Critical
Malware spreading to OT	High	High	High
Credential compromise	Medium	High	High
Production shutdown	Medium	Very High	High
Equipment damage	Medium	Very High	High
Safety incident	Low–Medium	Very High	High
Data theft	Medium	Medium	Medium

Business Impact

A successful attack could result in:

- Production shutdown.
- Manipulation of industrial processes.
- Equipment damage.
- Loss of product quality.
- Financial losses.
- Safety hazards.
- Environmental damage.
- Loss of confidential information.
- Regulatory and legal consequences.
- Damage to organizational reputation.

Risk Priority

The **highest priority** is protecting PLCs and critical control systems because unauthorized commands can directly affect physical processes.

5. Incident Response Plan

Phase 1: Identification

- Confirm the ICS alert.
- Identify source and destination systems.
- Determine whether the commands are legitimate.
- Identify affected PLC/SCADA systems.
- Classify the incident as a high-priority OT security incident.

Phase 2: Containment

Immediately:

- Block unauthorized IT-to-OT traffic.
- Isolate the compromised IT workstation.
- Disable compromised accounts.
- Restrict unnecessary firewall rules.
- Prevent further communication with critical PLCs.

Important: Critical PLCs should not be unnecessarily powered off because this could create safety or production problems.

Phase 3: Eradication

- Remove malware.
- Reset compromised credentials.
- Remove unauthorized applications.
- Patch vulnerable systems where safely possible.
- Correct firewall configurations.
- Remove unnecessary network routes.

Phase 4: Recovery

- Restore affected systems from trusted backups.
- Verify PLC configurations.
- Compare configurations with known-good versions.
- Test SCADA and PLC communication.
- Monitor the OT environment continuously.
- Reconnect systems gradually after validation.

Phase 5: Lessons Learned

After recovery:

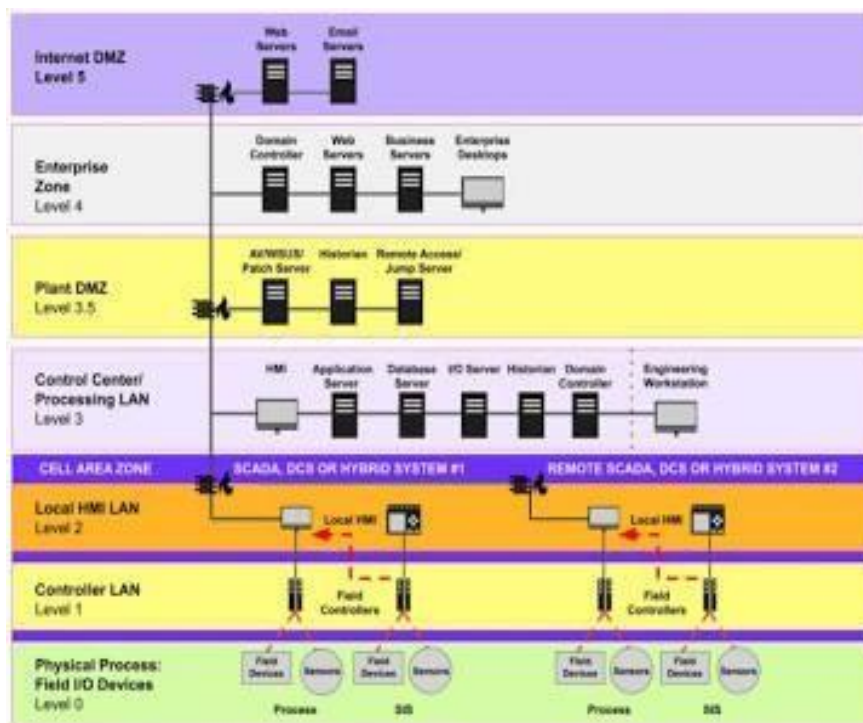
- Document the complete attack.
- Identify security-control failures.
- Update incident-response procedures.
- Improve network segmentation.
- Conduct employee security training.
- Perform regular OT security assessments.
- Conduct incident-response drills.

6. Mitigation Strategies and Security Architecture

A. Industrial DMZ

An **Industrial DMZ (Demilitarized Zone)** should be placed between the IT and OT networks.

Architecture



Justification

The industrial DMZ prevents **direct IT-to-PLC communication**. Systems requiring controlled communication can be placed in the DMZ, reducing the attack surface.

B. Allowlisting

Allowlisting allows only approved:

- Applications.
- Devices.

- IP addresses.
- Protocols.
- Ports.
- Communication paths.

For example:

Approved SCADA Server → PLC = ALLOW

Unknown IT Workstation → PLC = BLOCK

Unauthorized Application → PLC = BLOCK

Justification

Even if malware reaches an OT workstation, allowlisting can prevent unauthorized applications or commands from executing.

C. Jump Servers

A **jump server** acts as a controlled gateway for administrators.

Instead of:

IT PC → PLC

use:

IT PC → Jump Server → OT → PLC

The jump server should use:

- Multi-factor authentication.
- Role-based access control.
- Session logging.
- Strong authentication.
- Limited administrative privileges.
- Time-based access where appropriate.

Justification

Jump servers eliminate uncontrolled direct administrative access to critical OT systems and provide a centralized point for monitoring administrator activity.

D. OT IDS

An **OT IDS (Operational Technology Intrusion Detection System)** continuously monitors industrial network traffic.

It can detect:

- Unauthorized PLC commands.
- Unusual SCADA communication.

- New devices.
- Abnormal industrial protocols.
- Network scanning.
- Changes in normal traffic patterns.
- Suspicious IT-to-OT communication.

Justification

Traditional IT security tools may not fully understand industrial protocols or operational behavior. OT IDS provides visibility into the industrial environment and can detect abnormal activity without actively disrupting the process.

7. Final Recommendation

The organization should implement a **defense-in-depth architecture**:

IT Network → Firewall → Industrial DMZ → Firewall → OT Network → PLC/SCADA

The following controls should be prioritized:

1. **Industrial DMZ** – separates IT and OT.
2. **Strict firewall rules** – allow only required communication.
3. **Allowlisting** – permits only trusted applications and devices.
4. **Jump servers** – provide controlled administrative access.
5. **OT IDS** – continuously detects abnormal industrial activity.
6. **Strong authentication** – protects administrative accounts.
7. **Regular backups** – enable reliable recovery.
8. **Continuous monitoring** – detects future attacks quickly.

Conclusion

The unauthorized commands indicate a possible **IT-to-OT attack or compromised IT system**. The immediate priority is to contain the suspicious communication, investigate the source, verify whether PLC/SCADA systems were affected, and preserve evidence. The long-term solution is to implement strong **IT/OT segmentation using an industrial DMZ, allowlisting, jump servers, strict firewall policies, and OT IDS monitoring**. These measures significantly reduce the possibility of unauthorized access to PLC/SCADA systems and improve the organization's ability to detect, respond to, and recover from future ICS security incidents.